



GROUP ASSIGNMENT

CT128-3-2-ISC

IMPLEMENTATION OF SECURE SYSTEM

APU2F2411CS(CYB) - APD2F2411CS(CYB)

HAND OUT DATE: 14th MAY 2025

HAND IN DATE: 20th JUNE 2025

WEIGHTAGE: 20%

INSTRUCTIONS TO CANDIDATES:

1. Assignment is to be submitted through online submission (Moodle).
2. Students are advised to underpin their answers with the use of references (cited using the APA Name System of Referencing)
3. Late Submission will be awarded zero (0) unless Extenuating Circumstances (EC) are upheld.
4. The case of plagiarism will be penalized.
5. You must obtain 50% overall to pass this module.

MODULE NAME:	IMPLEMENTAION OF SECURE SYSTEM
MODULE INTAKE CODE:	CT128-3-2-ISC
LECTURER NAME:	DR. KAMALAKANNAN MACHAP
GROUP NO:	5
GROUP MEMBERS:	HEMANTHARAJAH A/L N KRISHNARAJAH (TP070844) ADAM JEROME JOSEPH (TP071194) SAILESS RAJ A/L RAJENDRAN (TP070996) ANUSHA DEVY BRAHMATARAN (TP071154) DARMIK ISHWAR A/L RAVI (TP070071)

Table of Contents

1.0 Introduction	4
2.0 Case Study Analysis.....	7
2.1 Introduction of the Case.....	7
2.2 Attackers Profile	11
2.3 Victims Involved	13
2.4 Technologies and Tools Used in the Attack	15
2.5 Targeted System in the Attack.....	17
2.6 Other Digital Assets	19
3.0 Proposed Security Techniques	21
3.1 Intrusion Detection System (IDS) – Hemantharajah A/L N Krishnarajah (TP070844).....	21
3.2 Security Information and Event Management (SIEM) – Adam Jerome Joseph (TP071194)	26
3.3 Multi-Factor Authentication (MFA) – Sailess Raj A/L Rajendran (TP070996).....	31
3.4 Intrusion Prevention System (IPS) – Anusha Devy Brahmataran (TP071154).....	37
3.5 Zero Trust Architecture (ZTA) - Darmik Ishwar A/L Ravi (TP070071).....	40
4.0 Conclusion	44
5.0 Work breakdown Structure	47
References.....	49

1.0 Introduction

SolarWinds began in 1999, founded by brothers Donald and David Yonce in Tulsa, Oklahoma. Frustrated by overly complex and expensive IT tools, they built something simpler because, let's face it, sometimes the easiest tools are the best tools. By 2001, SolarWinds had released its first web-based network performance monitoring tool, which became a hit among IT professionals who needed more user-friendly solutions (SolarWinds, 2024). In 2006, they relocated their headquarters to Austin, Texas, a move that reflected their ambition to scale up in the U.S. tech scene (SolarWinds, 2024). With support from investors like Austin Ventures and Bain Capital, SolarWinds went public in 2009, launching with a strong \$112 million IPO. Despite the 2016 decision by private equity firms Silver Lake and Thoma Bravo to acquire it, SolarWinds returned to the public market in 2018 (Investopedia, 2024).



Figure 1: SolarWinds logo

Over the years, SolarWinds grew through a mix of foundational software development and strategic acquisitions. Their approach was simple: build a free, quality product to attract users, then offer advanced versions to paying customers (SolarWinds, 2023). Products like Pingdom,

Papertrail, and Loggly expanded their reach in areas such as website performance, log management, and observability. According to a 2023 update, SolarWinds rebranded around a unified observability platform that also embraced AI and subscription-based models (SolarWinds, 2023).

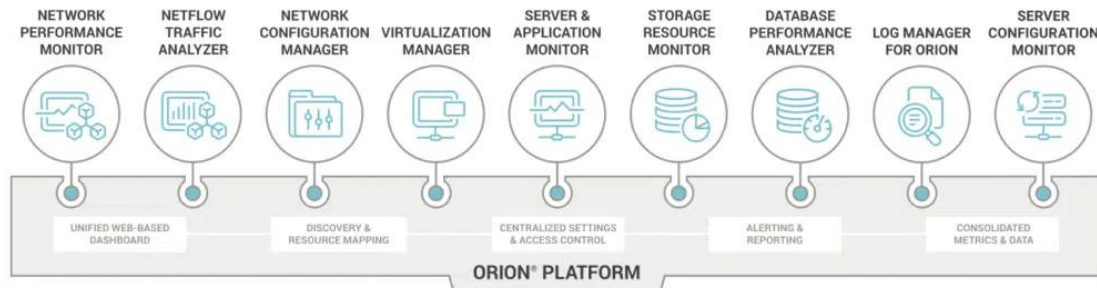


Figure 2: Orion Platform

By late 2023, SolarWinds reported around \$796 million in revenue and supported over 300,000 customers globally including very close to 100% of the Fortune 500 and multiple U.S. government agencies (GlobalData, 2023). Its core asset, the Orion Platform, is an IT management system offering network, systems, and database monitoring through modular products. These include Network Performance Monitor, Server & Application Monitor, and Database Performance Analyzer, letting organizations manage infrastructure across cloud and on-prem environments (Investopedia, 2024).

Another essential digital asset is Security Event Manager (SEM), SolarWinds' SIEM solution. This tool aggregates logs, correlates events, and raises alerts in real time. SolarWinds also offers endpoint detection and response (EDR), vulnerability scanning tools, and integrated SIEM workflows after acquiring TriGeo Network Security in 2011 (SolarWinds, 2024). These products are designed to give IT and SecOps teams better visibility, faster incident response, and compliance support across regulations like ISO 27001 and NIST.

The company also hosts a thriving user community called THWACK, launched 20 years ago with over 200,000 active members (SolarWinds, 2024). This community serves as a

collaborative space where users share scripts, ask for help, and vote on feature ideas. It's a real feedback loop: users share their needs, and SolarWinds builds accordingly. This grassroots approach has defined SolarWinds' brand: tech made by tech pros, for tech pros.

Yet despite this customer-centric and developer-friendly culture, SolarWinds' trusted reputation also invited the biggest supply-chain attack in history. When the SolarWinds breach happened in 2020, the tool most people relied on for monitoring became the Trojan horse that delivered malware. That risk underscores just how sensitive and powerful their assets are: code that is digitally signed, sent directly into high-security networks globally. It's not just software, it's a gateway to the inner workings of hundreds of thousands of systems (Pan & Li, 2023).

Today, SolarWinds is focused on rebuilding trust and security. Following the breach, the company embraced a "Secure by Design" principle, re-engineered its build processes, adopted multi-factor authentication (including YubiKey), and expanded its Security Operations Centers around the clock (SolarWinds, 2024). In April 2025, SolarWinds was taken private by Turn/River Capital in a \$4.4 billion deal, aimed at strengthening its product line in observability, hybrid cloud, and service desk automation, while continuing to give security top priority (SolarWinds, 2025).

To sum it up, SolarWinds has grown from a small startup into a major global provider of network, systems, database, and security monitoring tools. Its key digital assets include the Orion platform, SEM SIEM tool, endpoint security, and a deep integration of observability through acquisitions. While it continues to evolve in a hybrid-cloud, AI-driven IT world, SolarWinds is a classic example of how innovation, user focus, and software trust can lead to both success and vulnerability, especially when threats come knocking at the supply chain.

2.0 Case Study Analysis

2.1 Introduction of the Case

The SolarWinds cyberattack, also known as SolarWinds supply chain attack, Sunburst or Solorigate, is a classic example of a supply chain attack. This type of attack targets trusted software providers and uses them to spread malware into other systems. In SolarWinds' case, hackers secretly gained access to its internal network and added malicious code into Orion's software updates. These infected updates were digitally signed and looked like regular system upgrades, which made them even more dangerous. Starting around March 2020, these compromised updates were sent out to nearly 18,000 customers (TechTarget, 2023).

Investigations later revealed that the hackers had been inside SolarWinds' systems since September 2019. The attackers believed to be linked to APT29, a Russian state-sponsored group also known as Cozy Bear used a complex and stealthy method to stay hidden. They inserted their malware slowly, tested it, and made sure it wouldn't raise suspicion. This malware, called Sunburst, gave them remote access to affected systems and allowed them to spy, steal data, and move laterally across networks (CISA, 2020). Once installed, Sunburst would lay low for about two weeks before starting communication with the attacker's command and control servers. This was smart because it helped the malware avoid triggering basic security alerts.

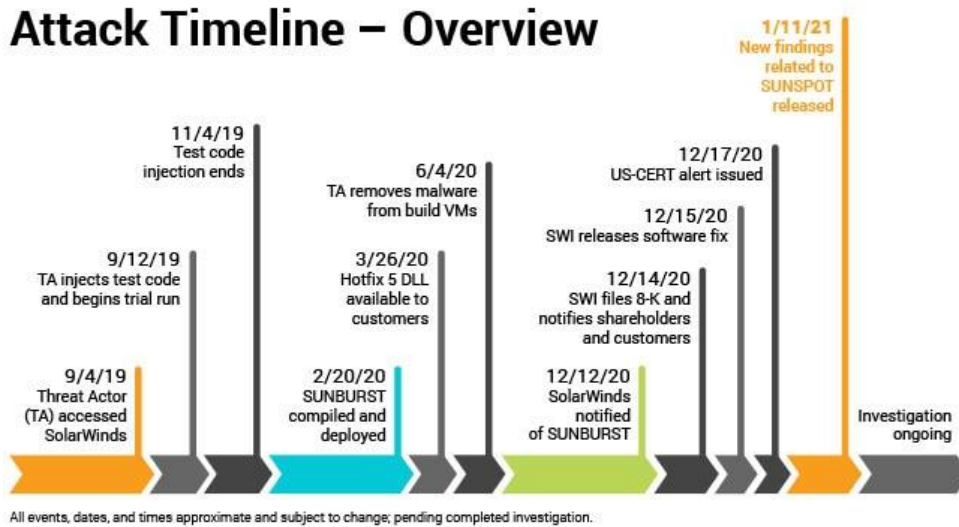


Figure 3: SolarWinds Attack Timeline – Overview (SolarWinds, 2021).

The attack went unnoticed for months. It wasn't until December 2020 that cybersecurity firm FireEye detected unusual behavior in their own systems. They began investigating and eventually traced the problem back to SolarWinds. FireEye's public report about the breach triggered a huge global investigation. Several U.S. federal departments including the Department of Homeland Security, Treasury, Commerce, and Justice were confirmed victims. Tech giants like Microsoft, Cisco, Intel, and many others were also impacted. In total, at least 100 organizations were deeply compromised, and the full list may still be unknown (Unit 42, 2020).

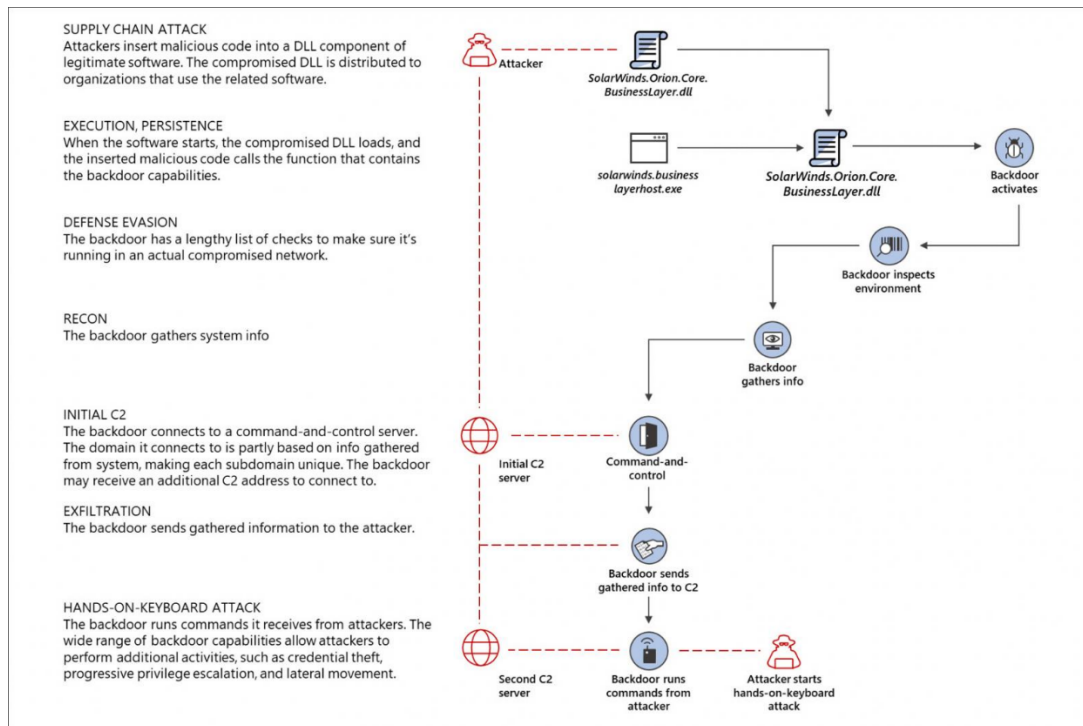


Figure 4: SolarWinds supply chain attack

This case shook the cybersecurity world. It showed how fragile even “secure” software environments can be. The fact that the attack came from inside a trusted software update made it really hard to detect using traditional methods. Even companies with advanced security tools including SIEM and firewalls struggled to identify the breach. It raised major concerns about how much we trust software vendors and how attackers are getting smarter about blending in.

The SolarWinds attack also taught us why modern security tools like SIEM and IDS (Intrusion Detection Systems) need to be better integrated and smarter. Organizations now realize that just buying security software isn’t enough. There needs to be real-time monitoring, anomaly detection, and stronger response protocols. For companies managing digital assets, especially those tied to critical infrastructure or government systems, this case was a wake-up call.

Overall, the SolarWinds case proves that even the most advanced organizations can become targets and victims of cyberattacks. It emphasizes the importance of securing not just data, but the entire software development process. From internal network monitoring to securing built

environments and verifying software integrity, everything needs to be checked constantly. This case changed how people look at digital asset protection and pushed companies to rethink their cybersecurity strategies from the ground up.

2.2 Attackers Profile

The cyberattack on SolarWinds, which was identified in the late 2020, is one of the most significant cyber espionage incidents in recent history, attributed to a highly skilled and advanced hacking group called APT29, also known as Cozy Bear. This group is believed to have support from the Russia government, particularly the Russian Foreign Intelligence Service (SVR). The attackers executed out a stealthy, long-term campaign, penetrating the software supply chain of SolarWinds, a leading provider of IT management software. Hackers inserted a backdoor called “SUNBURST” into the Orion software updates, allowing the hackers to gain access to the systems of SolarWinds’ clients, including 18,000 organisations, many of which were high-profile targets such as U.S government agencies and major corporations (NPR, 2021).

APT29’s modus operandi is highly focused on cyber espionage. The main objective in the SolarWinds attack was to collect intelligence from organisations with significant geopolitical and strategic value, including U.S agencies like the Department of Homeland Security, the Department of Defence and the Treasury Department. The attackers penetrated these organisations using trusted software updates which is a technique that bypassed conventional security defences. The attackers’ use of this supply chain attack is especially alarming, as it exploited the trust inherent in a software update process. This made it significantly more difficult to detect the breach, enabling the hackers to sustain long-term access to compromised networks (TechTarget, 2021).

The attack showcases APT29’s remarkable technical expertise and their ability to function undetected over long time. After penetrating SolarWinds’ Orion platform, which is commonly utilised for network management, the attackers inserted the SUNBURST backdoor, enabling them to oversee networks, steal data, and even manipulate systems at will. They demonstrated a level of caution typical of state-sponsored groups, choosing to evade detection instead of immediately disrupting systems. This allowed them to maintain a low profile and continue their espionage activities undisturbed for several months, gaining valuable intelligence on U.S. foreign policy, defence, and cybersecurity efforts (Aquasec, 2021).

APT29's penetration strategy is also notable for its accuracy and stealth. Instead of initiating random assaults or causing instant chaos, the group prioritised acquiring critical information that could provide Russia with a strategic advantage. Their cyber espionage operations have long been a hallmark of their activities, as they aim to access sensitive information from government and private sector targets, which may aid in advancing national interests. By integrating themselves into reliable systems, APT29 showed their sophisticated grasp of exploiting weaknesses in worldwide cybersecurity frameworks, rendering this attack not just extremely harmful but also one of the hardest to identify (TechTarget, 2021; Aquasec, 2021).

This attack has had major consequences for cybersecurity practices, especially in the area of supply chain security. It showed the vulnerabilities in the distribution of software updates and the potential risks of third-party providers. As a result, the SolarWinds hack has led to calls for more stronger security measures throughout the software supply chain, along with vigilance in monitoring and responding to advanced persistent threats (NPR, 2021).

2.3 Victims Involved

The SolarWinds cyberattack, disclosed in December 2020, affected a broad and high-profile range of victims, making it one of the most impactful cybersecurity breaches in modern history. At the core of the attack was the Orion platform, a widely used IT monitoring and network management software developed by SolarWinds. By injecting a malicious backdoor later dubbed SUNBURST into a routine software update, threat actors were able to stealthily infiltrate the networks of organizations that installed the compromised update. Approximately 18,000 SolarWinds customers were believed to have received the tainted version of Orion, but the attackers only selected a smaller group of high-value targets for deeper exploitation. Among the most notable victims were several United States federal agencies, including the Department of Homeland Security (DHS), the Department of the Treasury, the Department of Commerce, and the National Institutes of Health (NIH). The breadth of affected government entities demonstrated the attackers' strategic intent to gain access to sensitive political and economic information.

Beyond government institutions, numerous prominent private sector companies also fell victim to the attack. Technology giants such as Microsoft, Intel, Cisco, and FireEye were among those who confirmed unauthorized access to portions of their internal systems. FireEye, a leading cybersecurity firm, played a pivotal role in uncovering the breach when it discovered that its own Red Team tools used to simulate attacks for security testing had been accessed and possibly stolen. Microsoft, meanwhile, disclosed that attackers had viewed portions of its source code repositories, although there was no evidence of modification. These incidents emphasized the severity of the breach and its implications for the broader technology ecosystem. The nature of the attack targeting software supply chains meant that victims were not necessarily directly compromised by phishing or poor cyber hygiene but were instead affected through their trust in a vendor's update process. This raised alarms throughout the cybersecurity community, as it demonstrated how third-party software could be weaponized to bypass even sophisticated internal security measures.

Moreover, the attack extended to critical infrastructure sectors, financial services, healthcare providers, and academic institutions, though many affected entities chose not to disclose specific details publicly. Cloud services, particularly those built on Microsoft's Azure and 365 platforms, were also at risk, as attackers used stolen credentials to access email accounts, calendars,

and confidential files. The full extent of data exfiltration remains unknown, but it is widely believed that the information targeted included classified government documents, trade secrets, and sensitive communications. The victims of this breach were not only technically compromised but also faced legal, regulatory, and reputational consequences. Many had to undergo thorough forensic investigations, notify customers, and bolster internal controls. In some cases, Congressional hearings and shareholder scrutiny followed, particularly for companies that were found to lack sufficient monitoring or incident response protocols.

The SolarWinds case serves as a stark reminder that even the most secure organizations are vulnerable when a trusted vendor is compromised. It underscored the need for enhanced vendor risk management, deeper visibility into supply chain operations, and a shift toward a zero-trust security model. Victims learned hard lessons about the importance of segmenting networks, detecting lateral movement, and continuously monitoring for anomalies even in software updates from verified sources. The attack's wide-ranging impact continues to influence cybersecurity policy, with governments and corporations alike re-evaluating their defenses against supply chain threats.

2.4 Technologies and Tools Used in the Attack

The SolarWinds cyberattack stands out not only for its scale but also for the sophisticated technologies and tools employed by the attackers. At the heart of the campaign was the use of **SUNBURST**, a highly stealthy and obfuscated malware implant that was inserted into the digitally signed SolarWinds Orion platform update. Once downloaded and installed by unsuspecting clients, the malicious code lay dormant for a period of 7 to 14 days before initiating communications with command-and-control (C2) servers. During this time, the malware collected environmental information to determine whether it was operating in a sandbox or analysis environment. If deemed safe, SUNBURST proceeded to communicate through stealthy HTTP requests that mimicked legitimate SolarWinds API traffic, allowing it to remain hidden from conventional security monitoring tools.

The attackers behind the campaign demonstrated a deep understanding of software development practices and enterprise network architecture. The compromised DLL file used in the Orion update was signed using a valid digital certificate, making it appear trustworthy to systems and administrators. This approach represents a textbook **supply chain attack**, where instead of breaching targets directly, attackers manipulate software updates from a trusted third party. Once embedded within a target's network, SUNBURST enabled remote access, data theft, and lateral movement. To facilitate this, attackers deployed additional custom malware strains, such as **Teardrop** and **Raindrop**, which were used to drop Cobalt Strike beacons legitimate penetration testing tools repurposed for malicious activity. These beacons helped the threat actors establish persistence and control over compromised systems.

Another notable tactic used was the abuse of **SAML tokens** (Security Assertion Markup Language), a method that allowed attackers to forge authentication tokens and gain access to cloud services such as Microsoft 365. By compromising the Active Directory Federation Services (AD FS) server, the attackers generated their own SAML tokens, effectively bypassing multifactor authentication (MFA) and impersonating legitimate users. This allowed them to move laterally across cloud and hybrid environments undetected. The attackers also used **domain name generation algorithms (DGA)** and domain fronting to obfuscate their C2 infrastructure. These

methods helped hide the origin and destination of data exfiltration activities, making it extremely difficult for defenders to trace or block communications.

The SolarWinds attackers practiced extreme operational security (OpSec), rotating infrastructure and payloads, using time delays, and minimizing their footprint within logs. They often leveraged **living-off-the-land** techniques using legitimate administrative tools like PowerShell and Windows Management Instrumentation (WMI) to avoid detection. This meant that traditional signature-based antivirus or intrusion detection systems (IDS) were largely ineffective in identifying the attack. Additionally, by exploiting trust in signed code and using encrypted C2 channels, the attackers were able to evade behavior-based detection in many environments.

In sum, the SolarWinds attackers combined **supply chain compromise, malware engineering, cloud service manipulation, and advanced stealth techniques** to orchestrate a near-undetectable campaign. This event revealed the limitations of perimeter focused security models and emphasized the need for robust endpoint monitoring, behavioral analytics, and centralized logging systems. It also made a strong case for **Security Information and Event Management (SIEM)** platforms, which can correlate unusual patterns across disparate systems and help detect anomalies like forged tokens or unauthorized privilege escalations. Understanding the full range of tools and tactics used in the SolarWinds attack is essential for developing effective prevention and response strategies in the face of increasingly advanced cyber threats.

2.5 Targeted System in the Attack

The SolarWinds hack, has been uncovered in December 2020, was one of the most urbane and extensive cyberespionage campaigns on record. The attacker is believed to be a Russian state-backed collective, launched a supply chain attack to intrude the Orion Platform, which is a very famous network management software created by SolarWinds. By flexible the software update procedure, the attackers were able to insert a malicious backdoor (codenamed “SunBurst”) into legitimate Orion software updates. When such compromised updates were downloaded and installed by SolarWinds users, the backdoor was silently installed, granting attackers backdoor access to the targeted systems and networks.

Enterprise IT networks, cloud environments, inside databases, and email system were the primary systems compromised in SolarWinds. These were not arbitrary, hackers only attacked the companies that possessed valuable political, economic, or technological data. Some of those infected included giant U.S. government departments and agencies such as the Department of Homeland Security (DHS), Department of Treasury, Department of Commerce, Department of Energy (DOE), and the National Nuclear Security Administration (NNSA). Universities, Fortune 500 companies, and cybersecurity firms were also affected.

Email platforms were lucrative targets specifically. In some federal agencies, for instance, the attackers used unauthorized access to Microsoft Office 365 environments to read email and listen in on internal emails without triggering real-time detection. This allowed them to grant to sensitive communications, and some capable credentials, policy drafts, and intelligence reports. The attackers used advanced techniques to maintain the consistency in such systems which includes stealing authentication tokens and misconfigured permissions within cloud infrastructures.

The second main target was the Active Directory (AD), the main core of the of an enterprise network. Hacking AD would give attackers privilege escalation, network lateral movement, and migration to other systems or data stores. That allowed them to impersonate users, even admin accounts, and move further into sensitive environments.

In addition to email and identity infrastructures, the attackers do targeted software build environments and source code repositories, such as in the attack on Security firm FireEye. In that case, the attackers breached FireEye's Red Team tools advanced penetration tools employed to stimulate cyberattacks. Despite no suggestion they had ever been used in subsequent attacks, the theft was worrying about attackers exploiting security tools against companies.

Cloud infrastructure also got targeted. Hybrid setups that mixed on-premises infrastructure with cloud solutions, mainly Microsoft Azure, were employed by most of the victims. The attackers used stolen SAML tokens to impersonate users and gain more access to cloud resources which follows to the exploitation of the trust relationship between the setups.

The SolarWinds attack as an entity was not limited to a single type of system. Instead, it was universal penetration of basic digital properties, email format, Active Directory, cloud platforms, source code repositories, etc. The goal was not immediate disruption but long-term espionage data about strategic plans, technological development, and policy-making. The attack exposed the catastrophic scale of supply chain compromises and put strategic emphasis on end-to-end cybersecurity practices in public and private sectors.

2.6 Other Digital Assets

Despite the attackers in the SolarWinds cyberattack only focusing on certain systems, there are many other digital assets that also could have been exploited during this attack. One major example is industrial control systems (ICS), and supervisory control and data acquisition systems (SCADA). These are mostly used by factories, power plants, and utility companies to run physical machines. Even though they are often separated from normal IT systems, if attackers gain enough access, they could move laterally through the network and reach these environments. If that happens, they could disrupt water supply, power grids, or even transport services (SANS Institute, 2021). Another group of digital assets that attackers could have gone after is intellectual property (IP) and digital content. This includes files like source code, product designs, internal research papers, confidential reports, and customer databases. These types of files are often stored on shared drives, internal file servers, or version control systems like Git. If the attacker managed to steal this information, it could be used by competitors, leaked online, or sold on black markets. Even though this was not the main goal in the SolarWinds case, this kind of data has very high value and is a big target in many other cyberattacks.

Public-facing websites and domain name systems (DNS) are also important digital assets that could have been targeted. If attackers gain control over DNS settings or website content, they can redirect traffic to malicious websites, launch phishing attacks, or spread malware. They could even deface the website with false messages that hurt the organization's reputation. These kinds of attacks may not give the attacker secret data, but they can create confusion, panic, or damage trust in the brand. Attackers could have also gone after cloud backup platforms and data storage services, especially those hosted on third-party platforms like Amazon Web Services (AWS) or Microsoft Azure. These backups often store older versions of sensitive files and system configurations. If they are not protected with strong encryption or access controls, attackers could delete them, steal old data, or reintroduce malware through backup restoration. This is very risky because even if an organization thinks it has cleaned the system, the infection could come back (SolarWinds, 2022). Another sensitive area is financial and payment systems. These systems include payroll software, invoicing platforms, transaction records, and accounting tools. Attackers could have tried to tamper with payment data, delay transactions, or demand ransom after locking

the financial data. This could have led to serious financial losses or even legal problems (Arnold & Porter, 2021).

Finally, internal communication platforms such as Microsoft Teams, Slack, or Zoom are also at risk. These platforms store chat logs, video recordings, and file attachments. If attackers wanted to get access to these, they could have spied on internal conversations, impersonate staff members, or learn sensitive strategic information. Since many organizations now rely on these platforms for daily operations, they become high-value targets for long-term surveillance (Safeguard Cyber, 2019). Even though none of these systems were exploited during the SolarWinds incident, they show how wide the damage could be if the attackers wanted to go further. Therefore, other organizations should learn from this devastating incident and must protect all digital assets, not just servers and emails, to be safe in this digital environment.

3.0 Proposed Security Techniques

3.1 Intrusion Detection System (IDS) – Hemantharajah A/L N Krishnarajah (TP070844)

In today's digital world, organizations face an ever-growing range of cyber threats. While firewalls and antivirus software help block many of these attacks, they're not always enough. That's where **Intrusion Detection Systems (IDS)** come in. IDS don't block traffic like a security system, instead, it keeps an eye on everything happening inside a system or network and reports anything that looks suspicious. It works behind the scenes, watching, analyzing, and helping cybersecurity teams stay one step ahead of potential attackers.

The **SolarWinds cyberattack** in 2020 is a strong reminder of how even trusted software can be used to compromise secure environments. In this attack, the Orion software update used by thousands of companies was tampered with, allowing attackers to gain unauthorized access to sensitive systems. If a well-configured IDS had been in place across those networks, some unusual behavior linked to that update might have been noticed earlier. This could have helped reduce the damage and shorten the time it took to respond.

An IDS works by monitoring system activity or network traffic. It looks for anything that doesn't fit the usual behavior, such as strange login times, unexpected connections, or data transfers to unknown locations. When something suspicious is found, the system raises an alert so security staff can check it out. Some IDS platforms are even smart enough to use machine learning to detect new types of threats that haven't been seen before.

There are two common types of IDS. **Network-based IDS (NIDS)** checks everything going through the network, like traffic from users and apps. It's great for spotting threats like scanning, spoofing, or data exfiltration (Panigrahi et al., 2024). **Host-based IDS (HIDS)** focuses on a specific computer or server. It monitors files, logs, and user actions. This helps find local threats like malware or privilege abuse. In large systems, especially in supply chains like SolarWinds, using both types together gives much better protection.

To help understand how IDS works in a step-by-step way, have a look at the flowchart below. It breaks down the main stages of IDS from start to finish.

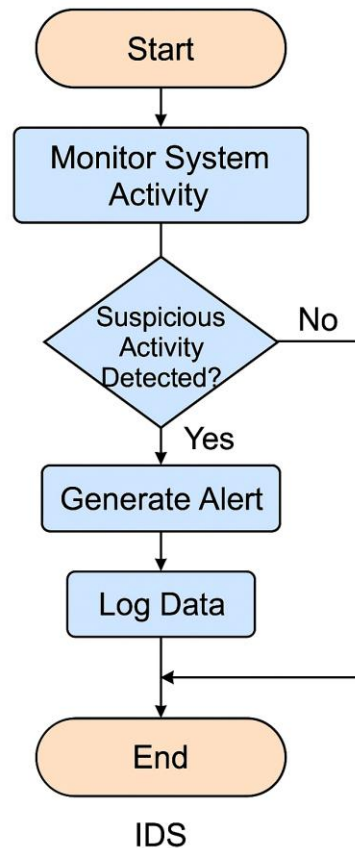


Figure 5: Flowchart of Intrusion Detection System Workflow

In this diagram, the process begins at **Start**. The IDS begins by **monitoring system activity**, such as traffic flow, user behavior, and file access. Then comes the decision-making point: **Is any suspicious activity detected?** If the answer is no, the system simply ends that cycle and continues monitoring silently. But if the answer is yes, the IDS moves into action, **generates an alert** and **logs the data** for further review. After this, the process concludes, marked as **End** in the diagram.

This setup ensures that the IDS does not waste resources on false alarms, while still logging everything important. That log data becomes a goldmine during forensic analysis if a breach is later confirmed. Even better, these logs can feed into **Security Information and Event**

Management (SIEM) tools, which can combine alerts from multiple sources and spot patterns across the network.

Now, to understand how IDS fits into a larger IT environment, we can refer to a **high-level network architecture diagram**. It gives us a broader view of how data flows through the system and where the IDS plays its role.

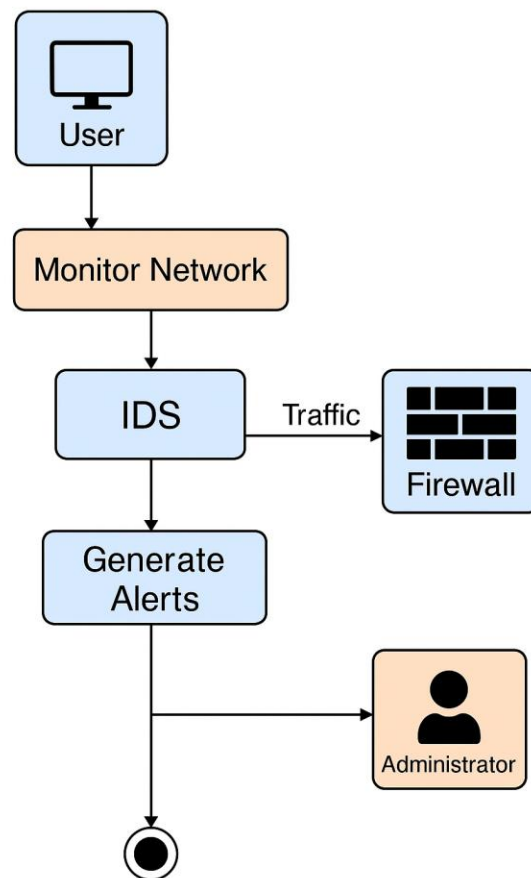


Figure 6: IDS-Based Network Monitoring Architecture

This diagram shows the entire chain of events in a modern digital system. A **user** initiates some network activity, maybe logging in, uploading a file, or accessing a cloud service. This action passes through the “**Monitor Network**” layer, which continuously watches for any unusual patterns. The **IDS** comes next, acting as the central point of analysis. It inspects traffic and behavior, using either predefined rules or anomaly detection to flag issues.

If the IDS identifies something questionable, it forwards that data to the **security system**. The security system can then act on this alert, like blocking access or isolating a machine. Meanwhile, the IDS also **generates alerts**, which are sent to the **administrator** for human review. This ensures that automated systems and human decision-makers both play a role in stopping the threat.

This setup is powerful because it links both automated and manual layers of defense. While a security system might miss a hidden backdoor, an IDS could detect strange behavior and escalate it. And if it's connected to the security system, it can act much faster. Meanwhile, human analysts can review alerts for deeper investigation or incident response.

In real life, this kind of architecture is used in big organizations like hospitals, banks, or government departments. They rely on IDS to protect data, ensure compliance, and meet regulations. For example, frameworks like **ISO/IEC 27001**, **GDPR**, and **NIST SP 800-53** all highlight the importance of continuous monitoring and incident detection. So, IDS is not just a cool tech tool, it's a legal and operational requirement in many industries.

Another important point is that IDS systems can help after an incident, not just during one. If there's a breach, the logged alerts and traffic data help security teams trace how it happened. This is critical for patching the system and preventing it from happening again.

But like any tool, IDS needs proper setup and tuning. If it's too sensitive, it sends too many alerts, and people start ignoring them. If it's not sensitive enough, it misses real threats. That's why many organizations today use **AI-enhanced IDS**. These systems learn what "normal" looks like in your network and can adjust automatically as things change. This makes them more accurate and useful in complex environments.

So how would this have helped in the SolarWinds attack? Even though the Orion update was digitally signed and appeared normal, once installed, it started behaving strangely. It contacted unknown domains, executed scripts, and moved laterally within networks. These are exactly the kinds of actions a smart IDS would detect. Even if the software looked safe on the surface, the IDS would catch the **behavior**.

In summary, an Intrusion Detection System is a key part of a secure IT environment. It doesn't stop threats on its own, but it gives early warnings and detailed insight. When combined with other tools like firewalls and SIEM, it becomes a powerful defense (Muhammad, Sukarno, & Wardana, 2023). The diagrams above help visualize both the **step-by-step process** and the **larger role** IDS plays in protecting networks.

For modern organizations and especially for companies involved in large-scale IT systems like SolarWinds, using IDS is not optional. It's essential for staying secure, compliant, and ready to respond.

3.2 Security Information and Event Management (SIEM) – Adam Jerome Joseph (TP071194)

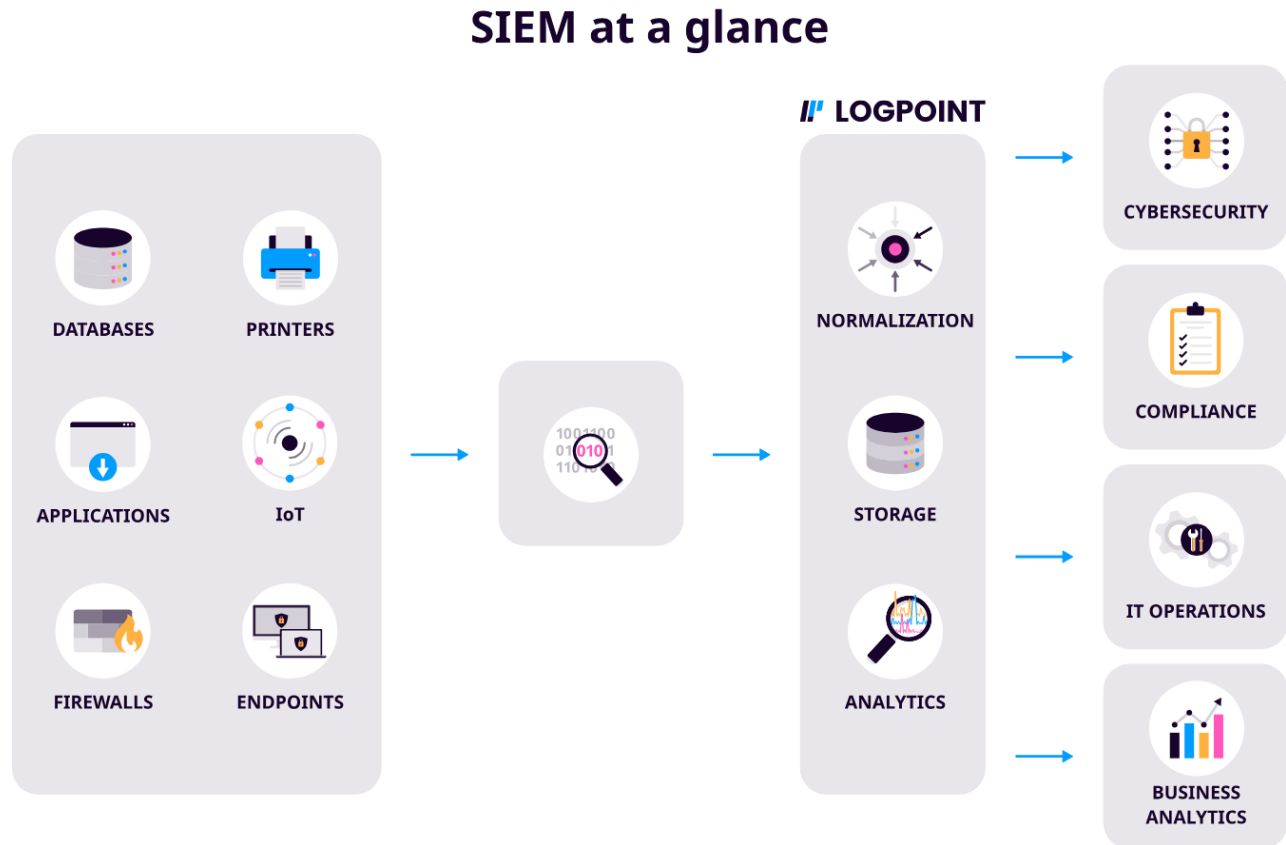


Figure 7: Security Information and Event Management (SIEM) briefly

To defend against advanced supply chain attacks like SolarWinds, organizations should implement Security Information and Event Management (SIEM). SIEM is a security solution that collects and analyses data from various sources in real-time. This includes logs from firewalls, intrusion detection systems, servers, cloud services, and applications. It helps security teams identify unusual behaviors, generate alerts, and respond to incidents quickly (IBM, 2023). In the case of SolarWinds, attackers stayed hidden in networks for months by blending in with normal traffic. If a SIEM system had been in place and properly configured, it could have correlated log data from different systems and raised early red flags. For example, SIEM could detect unusual

outbound traffic from Orion clients, abnormal logins at odd hours, or unauthorized changes to system configurations.

The real strength of SIEM is in centralizing all security data and spotting hidden patterns across the network, even if each system alone does not look suspicious. With automated alerts and dashboards, security teams can reduce response time and act before serious damage happens. By adding SIEM to their cybersecurity defense, organizations gain deeper visibility, improved threat detection, and a better chance of catching sophisticated attacks early (Splunk, 2023). In addition to detecting hidden patterns, SIEM is also helpful because it can link events that happen in different parts of the system. This is called event correlation, and it means that even if one small sign of danger looks normal, SIEM can put many small things together and show a bigger problem. For instance, a strange login, followed by a sudden configuration change and then unusual network traffic. Viewing these suspicious activities on its own might seem reasonable. But after looking at the suspicious activities altogether, it clearly indicates that an attack is taking place. Therefore, it is another reason why SIEM would have been useful in this attack. (AlienVault, 2022). Another key thing SIEM can do is store historical logs. In the SolarWinds attack, the hackers were inside the system for many months without being noticed. They moved slowly and tried not to look suspicious. With SIEM, you can go back and investigate logs from months before, and this is important for understanding how the attack started and what systems were affected. Many normal tools only show real-time activity, but SIEM keeps everything for long-term review. This is very useful during forensics or audit processes.

Besides that, SIEM tools often come with threat intelligence integration. This means that the system does not only look at your own data, but it also compares it with known lists of bad IPs, domains, and malware signatures from outside sources. This helps organizations to detect threats even faster because they do not need to figure it out all by themselves. In SolarWinds, if a threat intel feed already had the command-and-control (C2) server used by the attacker, SIEM could detect it and send alerts before more damage was done (AT&T Cybersecurity, 2022). Moreover, some modern SIEM systems also support SOAR (Security Orchestration, Automation and Response). This allows faster reaction because the system can respond to threats automatically. For example, when a serious alert is found, it can block a user, isolate a machine, or shut down a service without waiting for a human to react. In the case of SolarWinds, where every minute the

attacker stayed hidden made things worse, SOAR would help limit damage quickly (Palo Alto Networks, 2023). In addition, SIEM supports compliance requirements. Organizations usually need to follow rules such as ISO 27001, GDPR or industry-specific regulations. SIEM helps by keeping logs, creating reports, and showing that the system was monitored and protected. In SolarWinds' case, poor visibility and lack of logs made it harder to investigate what happened. If SIEM was used, it would provide a full record that could be used during security audits or legal investigations. SIEM is also scalable and adaptable. Despite the organization being small or large, SIEM can be configured to suit different environments. It can work in on-premises settings or on cloud platforms. This flexibility is important because the attackers in the SolarWinds case moved between local servers and cloud infrastructure. A good SIEM system can see everything that happens across all layers of infrastructure.

Some people think SIEM is hard to use or creates too many alerts. But with the right setup and tuning, false alerts can be reduced. It's important that organizations do proper rule creation, filtering, and regular updating of correlation rules. Also, SIEM should be part of a bigger security program. It's not a magic solution, but when used correctly, it provides strong benefits for early detection, fast response, and clear understanding of threats. To sum up, SIEM gives organizations the ability to see threats sooner, respond faster, and investigate better. In the SolarWinds breach, where attackers acted like normal users and moved silently, only a system like SIEM that collects data from everywhere and puts the pieces together can really detect such advanced threats. It also supports automated action, historical analysis, and external threat intel, all of which are needed to protect digital assets today.

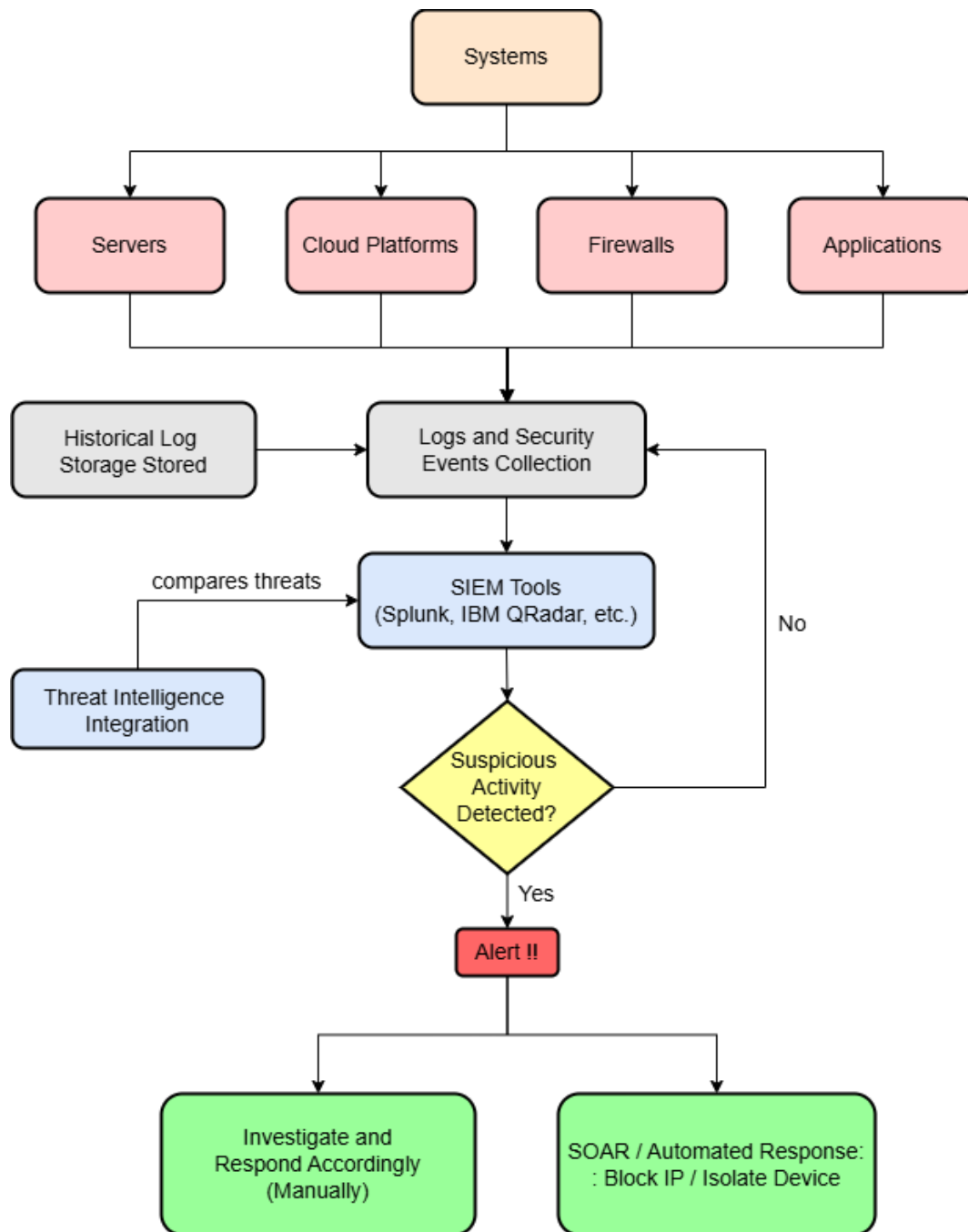


Figure 8: Flowchart of how SIEM would work and be applied in the SolarWinds attack

Figure shows how SIEM works by showing the flow of data from systems all the way until a security response is made. It helps show how different parts work together to detect suspicious activities and respond fast to possible attacks. This flow is very useful in helping companies stay alert and catch threats before it's too late. It starts with different systems like

servers, firewalls, cloud platforms and apps. These are the places where security logs and events usually come from. All of them are connected to one main process called “Logs and Security Events Collection.” This means that anything happening in the systems, whether normal or abnormal is collected into one place. This step is important because without data being collected, you will not be able to detect and identify if something is going wrong.

After logs are collected, they are also combined with historical log storage. This helps in looking at past activities and comparing them with current ones. At the same time, all these logs are sent to the SIEM tools, like Splunk or IBM QRadar. These tools are the “brain” of the diagram. They are the ones that analyse the logs and compare threats. They do not just look at logs individually but instead they correlate them. Correlation means connecting the dots between different activities. Something that looks small in one place can be connected to another small event elsewhere, and together they can point to a threat. There is also a connection to threat intelligence. This means SIEM tools not only look at what is happening inside the system, but they also compare it with known bad actors outside, like blacklisted IPs or domains already identified as dangerous. This helps to catch threats faster and from a wider angle. Then, we come to the decision part of the diagram. SIEM tools will try to investigate and identify if there are any suspicious activities taking place. If the answer is no, it stops there, and no action is taken. But if the answer is yes, then an alert is triggered. Once the alert is raised, there are two paths to take. One is manual investigation where the organization or cybersecurity team checks the suspicious activity taking place and acts accordingly. On the other hand, SOAR responds automatically to threat, which can isolate a device or block an IP by itself without waiting for the organization or cybersecurity team to react. Both responses are important depending on the type and seriousness of the attack.

This whole flow shows how SIEM is not just about collecting logs, but about making sense of everything from different sources, comparing it with outside threats, and reacting fast. On top of that, SIEM allows you look back at historical data which helps cybersecurity teams know the timeline of what and when the attack or suspicious activity took place. This will help organizations and cybersecurity teams in preventing attacks in the future.

3.3 Multi-Factor Authentication (MFA) – Sailess Raj A/L Rajendran (TP070996).

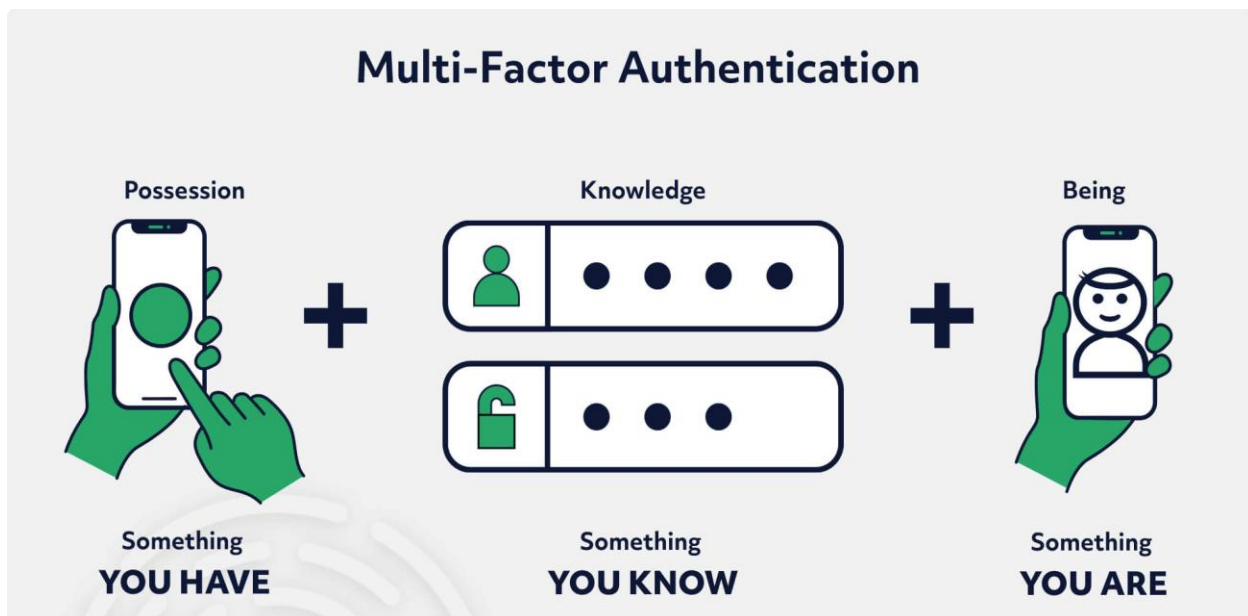


Figure 9: Multi-Factor Authentication (MFA)

In the modern era, where business confidential things, people's information, and the honesty of national infrastructure depends on the veracity of systems based on the net, the weakness of the outdated password has been frankly obvious. Multi-Factor Authentication (MFA) has been rising as the mandatory countermeasure, changing the method in which entree to essential systems is protected. To get to know of MFA, its main advantages, and its specific relevance to the situation of major cyber-attacks which is the 2020 SolarWinds supply chain attack is to direct appropriately in today's threat scenery. Meanwhile, MFA is a foundation level of security, greatly heightening the block for attackers and which show its critical, if it's not perfect, function in preventing even the most sophisticated breaches from imposing their damage.

Mainly, when the Multi-Factor Authentication is being mentions to an authentication flow that mainly needs or requires from the users two or more specific verification factors before getting access a resource, such as an app, system, or database (National Institute of Standards and Technology (NIST), 2017). With this kind of method can clearly moves way more the sole dependence on "something you know", typically a password, that is very suspicious to theft such

as like phishing, brute-force attempts and credential stuffing due to big data leak (Florencio, 2007). MFA demands evidence from non-independent factors which are knowledge such as PINs and passwords, possessions which is a token like a smartphone with authenticator software or a hardware key and inherence (biometric data like fingerprints or face recognition) (National Institute of Standards and Technology (NIST), 2017). MFA's authority lies in the diversity which comprising one factor such as compromised password, which is not enough for not recognizable access without comprising the second independent factor as well Krombholz, 2015). Multi-layer authentication creates a threatening block for hackers who try for illegal access.

The advantages of MFA are widespread and thoughtful. To begin with, it will lessen the risk of account takeover by a mile due of its resistance to be guessed or hijacked passwords. Even if the attackers have the valid credentials through phishing and breach, the absence of the second factor reduces authorizations virtually which are not useful for getting more access (Das, 2014). This does so straightforward against the widespread attack vectors such as the credential stuffing, where the attackers hijack the username or password matches and reuse for several services. Some forms of MFA, mainly those based on FIDO2/WebAuthn standards through the hardware security keys or platform biometrics does offer good defence against the advanced phishing attacks that try to steal the passwords and one time code or OTP (FIDO Alliance., n.d.) Additionally, to fending off specific attacks the MFA raises general accountability by having better assurance and guarantee that the authentic user is getting into their account. It supports the organizations with even a lot of stringent regulatory compliance requirements in numerous incidents such as Finance (FFIEC), healthcare (HIPAA) and data privacy (GDPR), which suggest stringent authentication controls in most situations (PCI Security Standards Council, 2019).

The terrible SolarWinds supply chain breach of 2020 offers a case study for appreciating the contextual utility and the limitations of MFA in the face of a sophisticated, nation-state threat. In the attack, attackers compromised the software build environment of SolarWinds, a major vendor of IT management software, and have implemented a backdoor ("SUNBURST") in legitimate updates to its Orion product (CrowdStrike, 2021). Millions of customers, which includes numerous U.S. government agencies and Fortune 500 companies, unintentionally installed the spoiled updates, which gave the attackers determined, stealthy access deep within their networks (FireEye, 2020). The early attack vector which infecting the SolarWinds inside systems and build

process were highly sophisticated and bypassed the normal perimeter defences by taking the trusted software update flow. This early intrusion did not have mainly of stealing the individual credentials via methods directly countered by MFA. It was stated and written that attacks had potentially gained initial access via the use of a weak password which is solarwinds123 on an internet server (United States Senate Select Committee on Intelligence, 2021). Therefore, MFA, since its mainly designed to secure user authentication points, would not have been in a place to prevent the supply chain compromise itself or the early planting of “SUNBURST” malware in victim networks. MFA does not offer in any direct protection against weaknesses in software development lifecycles, compromised code signing, or weak infrastructures (MITRE ATT&CK. (n.d.), n.d.).

However, to say MFA was not related to the SolarWinds attack would be a deep misperception. Its true defensive value became intensely applicable in the post-compromise stage within the victim networks. Having compromised “SUNBURST” in a network, attackers has diverted their attention to lateral movement, privilege escalation (obtaining Domain Admin or cloud admin rights), and to accessing some high-value data (CrowdStrike, 2021). This phase is heavily reliant on credential access techniques where attackers used tools to collect credentials in memory such as LSASS or on disk to take on the identity of valid users and move around in the network via protocols like SMB and RDP, a tactic known as “pass-the-hash” or “pass-the-ticket” (MITRE ATT&CK. (n.d.), n.d.). This is precisely where vigorous MFA implementation acts as a credible mitigation. If it’s not weak, phishing-resistant MFA such as FIDO2 security keys had been rigorously applied to the administrative accounts accessing high-value resources domain controllers, cloud admin portals (Azure AD, AWS), databases containing sensitive data, VPNs, and jump hosts, the attacker would have been drastically handicapped. Even if the administrator’s password is managed to be steal, the physical security key or biometric aren’t able to be possessed due to require completing the login. This forces attackers to employ significantly more sophisticated, time-consuming, and risky techniques t bypass MFA, such as advanced adversary-in-the-middle (Aitm) attacks targeting the authentication process, which are less successful and more likely to trigger detection alerts (MITRE ATT&CK. (n.d.), n.d.)

The tactical impact of this obstacle couldn’t be overstated. Organizations that have been possessed well-established Identity and Access Management (IAM) practices that supported them,

including implementing stringer MFA on privileged accounts, routinely held the attackers' privilege escalation actions in check and their capacity to access their ultimate objectives in their environments (Cybersecurity and Infrastructure Security Agency (CISA), 2021). MFA effectively limited the blast radius, hindered lateral movement, minimized data exfiltration, and increased the chances to detect through failed authentication activity on sensitive systems. As the U.S. Cybersecurity and Infrastructure Security Agency (CISA) underlined in its SolarWinds guidance, "Implementing MFA on all user accounts, especially privileged accounts, is one of the most useful ways to lessen the risk of credential theft and abuse" (CISA, 2021, p.8). So, while MFA would never have been able to stop the original attack vector, its widespread and stringent adoption within the victim organizations before the attack would have been a substantial which lessen the factor, converting potentially catastrophic leak into more containable security incidents.

The SolarWinds attack was a reminder of the main principle of cybersecurity today which is defence in-depth. There is not one control that is immune to each of the threat. MFA is no magic bullet that can keep out the sophisticated supply chain intrusions. But its non-existent on the critical internal entry points is an opening that sophisticated attacker will aggressively exploit once they've gained a foothold. MFA will remain one of the best and lowest-cost security controls available. It greatly raises the cost and complexity of the attacker, particularly at the most critical stage of lateral movement upon initial compromise. The SolarWinds takeaways are clear which is making strong, phishing immune MFA, mainly for the privileged accounts, a reality is not just a good practice to be nudged toward; It's a basic element of cyber hygiene, a virtual deadbolt that can radically alter the course of even the most sophisticated attack. Threats continue to evolve but MFA is a precious asset in the tech security world.

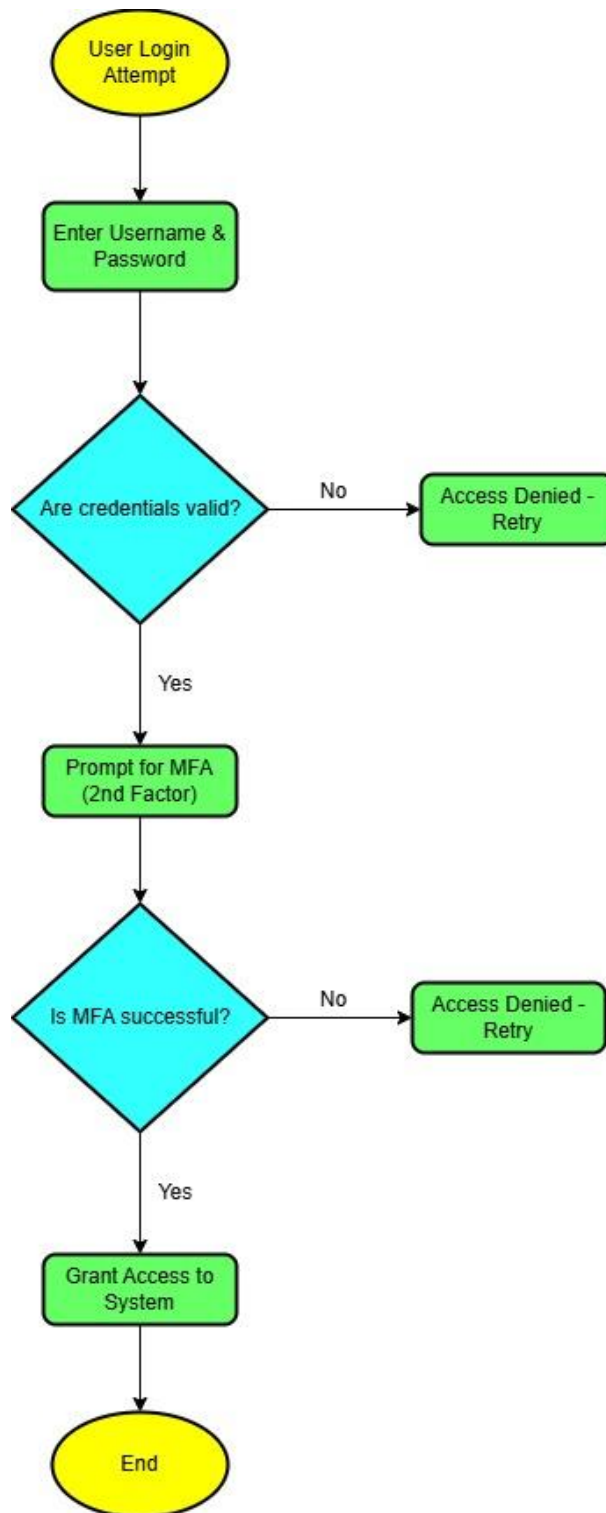


Figure 10: Flowchart of how Multi-Factor Authentication (MFA) will be applied in the SolarWinds attack.

The Figure above shows a flowchart representing the user authentication process with Multi-Factor Authentication (MFA), the process begins with when a user attempts to log in by inputting the individual the password or username. The system first authenticates these credentials. If they are wrong, the access will be denied on the spot, and the user will be requested to attempt again. If the credentials are correct, the system will proceed to the next layer of security. It will ask the user for second authentication factor (MFA). This can be an authenticator app code, a hardware token, or a biometric fingerprint. The system then verifies the second factor. If MFA verification fails, the access is again will be denied and the user can attempt the login process all over again. Only after successful authentication of the initial credentials and the second factor is full access provided to the user. Finally, the process is finished.

3.4 Intrusion Prevention System (IPS) – Anusha Devy Brahmataran (TP071154)

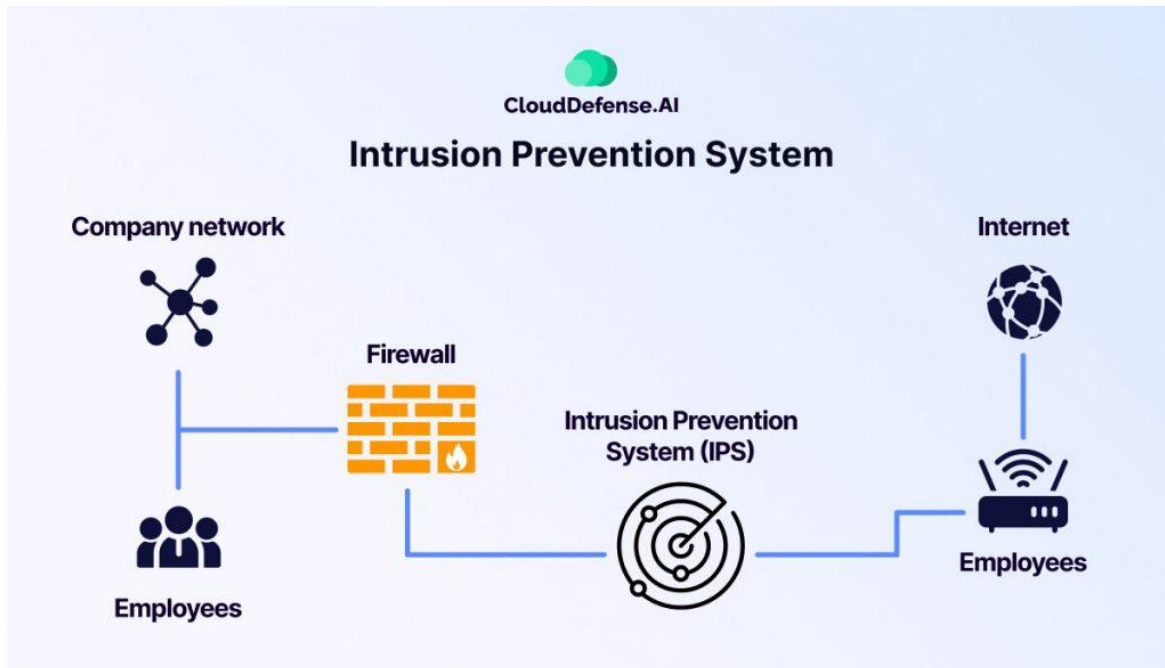


Figure 11: Intrusion Prevention System

An Intrusion Prevention System (IPS) is a vital tool in securing networks against potential threats. Unlike Intrusion Detection Systems (IDS), which only detect suspicious activities and notify security teams, an IPS actively works to block malicious activities in real-time. By continuously monitoring network traffic, an IPS identifies and responds to potential threats by analysing traffic for known attack signatures, abnormal patterns, or irregularities that deviate from normal network behaviour. It offers proactive protection against a range of cyberattacks, including malware, denial of service (DoS) attacks, and data exfiltration (VMware, 2021; Fortinet, 2021).

In the case of the SolarWinds attack, an IPS could have been a crucial defines mechanism to detect and prevent the malicious activities carried out by the attackers, APT29 (Cozy Bear), a Russian-backed cyber espionage group. The attackers compromised SolarWinds' Orion software updates by inserting a backdoor, "SUNBURST," into legitimate software updates. These updates

were then distributed to over 18,000 SolarWinds customers, including government agencies, critical infrastructure companies, and private businesses. Once inside the networks, the attackers used sophisticated methods to move laterally through compromised systems and exfiltrate sensitive data undetected for several months (IBM, 2021; Palo Alto Networks, 2021).

If an IPS had been implemented within the affected networks, it could have significantly reduced the attack's impact. For example, after the attackers embedded the SUNBURST backdoor, they needed to establish command-and-control (C2) channels to communicate with external servers and exfiltrate stolen data. An IPS could have been trained to recognize these unauthorized outbound traffic patterns, a key indicator of a data breach or malware activity. The IPS would have been able to block this traffic in real time, preventing the attackers from continuing their operations and notifying security teams of the breach (GeeksforGeeks, 2021; Catonetworks, 2021). Blocking unauthorized outbound traffic is a critical function of an IPS, particularly in situations like SolarWinds, where data exfiltration was a central goal of the attackers.

One of the key strengths of modern IPS systems is their ability to go beyond known attack signatures and leverage behavioural analysis to detect anomalous activity. In the SolarWinds attack, the attackers used advanced techniques to ensure they remained undetected for months. An IPS could have monitored network behaviour and identified subtle signs of lateral movement, privilege escalation, and other abnormal activities. By establishing baselines for typical network behaviour and comparing ongoing traffic against this baseline, an IPS could have identified deviations indicative of the attack. This behaviour-based detection could have provided early warning of the breach, enabling quicker identification and containment of the threat (Fortinet, 2021; Palo Alto Networks, 2021).

Beyond blocking initial exfiltration attempts, an IPS could have prevented further lateral movement within compromised networks. After the attackers established initial access via the Orion software update, they used various methods to move within the network and escalate their privileges. The IPS could have detected and blocked any attempt to exploit other vulnerabilities for lateral movement, preventing the attackers from accessing more sensitive areas of the network. Additionally, any attempt to deploy additional malware, such as trojans or ransomware, would

likely have triggered the IPS, stopping further malicious payloads from spreading (IBM, 2021; Catonetworks, 2021).

In addition to detecting abnormal behaviour in the network, an IPS could have added an extra layer of protection by analysing the software update process itself. Since the SolarWinds attackers leveraged trusted software updates to distribute malware, monitoring these updates for unauthorized modifications would have been another way an IPS could have detected the attack. By inspecting the software update traffic for irregularities or discrepancies in the files being downloaded, the IPS could have flagged suspicious updates before they were deployed across the network. This would have provided a proactive defence mechanism, ensuring that even if an attacker had infiltrated the system, their ability to deploy further malicious code or propagate within the network would have been mitigated (Palo Alto Networks, 2021).

In the context of the SolarWinds breach, an Intrusion Prevention System (IPS) would have been an invaluable tool in protecting the organization's digital assets. While the SolarWinds attack exploited the trust inherent in software supply chains, an IPS could have acted as a barrier, detecting and blocking unauthorized data exfiltration, lateral movement, and other malicious activities. By monitoring network traffic in real time, leveraging behavioural analysis to detect anomalies, and blocking suspicious outbound traffic, an IPS could have mitigated the impact of this attack. Moreover, by analysing software update traffic and identifying unauthorized modifications, an IPS could have helped prevent the spread of the SUNBURST malware, adding an additional layer of defence. Implementing an IPS could have greatly reduced the scope of the SolarWinds attack, highlighting the critical need for proactive security measures in modern IT environments.

3.5 Zero Trust Architecture (ZTA) - Darmik Ishwar A/L Ravi (TP070071)

The SolarWinds cyberattack really opened the world's eyes to just how dangerous it can be to trust everything inside a network. In that case, attackers didn't break in the traditional way they got in by slipping malicious code into a software update from a trusted vendor, SolarWinds. Thousands of organizations installed it, thinking it was safe. That trust ended up giving attackers the keys to the kingdom, letting them move quietly through networks, steal sensitive data, and remain undetected for months. That's exactly why I believe a **Zero Trust Architecture (ZTA)** is one of the most important security controls an organization can put in place today.

At its core, Zero Trust is based on a simple idea: don't trust anything by default, not even things inside your own network. Instead, every request whether it's from a user, device, or application needs to prove it's legitimate before it's allowed to access anything. This is very different from the traditional "castle-and-moat" approach, where once you're inside the network, you're trusted. Zero Trust changes the mindset to "always verify," which could have made a big difference in a case like SolarWinds.

Let's say an organization had a Zero Trust setup in place during the SolarWinds breach. Even if the attackers got inside through the compromised Orion software, they wouldn't have been able to move around freely. Access to systems would be tightly controlled, based on things like who's asking, what device they're using, where they're connecting from, and even what time of day it is. If something looked off for example, an admin account suddenly logging in from another country or accessing a server it never usually touches it would raise red flags. In some cases, it might even block access automatically or ask for extra verification.

To make ZTA work in real life, there are a few key tools and strategies that come together. First, identity is everything. Systems like **Microsoft Entra ID**, **Okta**, or **Ping Identity** manage who has access to what, making sure users are who they say they are using **multi-factor authentication (MFA)** and strict role-based access. Then, there's **device trust**. With tools like **Intune** or **Jamf**, companies can make sure that only secure, managed devices are allowed to connect. If your laptop is missing updates or has suspicious software, you can be blocked or quarantined before you access anything important.

Another major part of ZTA is **micro-segmentation**. Think of it as putting up internal walls between different parts of your network. Even if someone breaks in, they can't easily jump from one system to another. Tools like **VMware NSX** or **Cisco Tetration** help do this by controlling how systems talk to each other and blocking anything unusual. This would have been crucial in stopping the attackers in SolarWinds from pivoting between email servers, cloud environments, and databases.

On top of all this, continuous monitoring is key. With behavioral analytics tools like **Exabeam** or **Microsoft Sentinel**, security teams can spot when something doesn't look right. For example, if a user starts accessing systems they've never touched before, or downloads massive amounts of data at strange times, those tools can trigger alerts or even automatic responses. It's like having a security guard who's always watching for anything out of the ordinary.

The beauty of Zero Trust is that it doesn't rely on just one line of defense. It layers protection at every level user, device, network, and data. Even if one part is breached, the others are still standing. In contrast, the SolarWinds attack showed how dangerous it is to have flat trust across a network. Once the Orion update was installed, the attackers could do almost anything they wanted.

Of course, Zero Trust isn't something you flip on overnight. It requires planning and a shift in mindset. You need to first understand what digital assets you have, who needs access to them, and what normal behavior looks like. Then you start building policies around that. It might start with just requiring MFA for everyone or limiting admin access to specific hours and devices. Over time, you add in more layers, like network segmentation or stronger cloud controls.

Now, it's important to be realistic Zero Trust does have its challenges. It can be complex to set up, especially in large companies with legacy systems. There can also be some pushback from users who don't like the extra steps. But with proper training, good user experience design, and a phased rollout, these issues can be managed. And honestly, the alternative doing nothing and hoping you're not the next SolarWinds is far riskier.

In fact, the U.S. government has already started pushing agencies toward Zero Trust with official guidance and frameworks, like the one from NIST (SP 800-207). It's becoming the new standard, especially in industries where sensitive data and constant cyber threats are a reality.

Organizations that start now will be far better positioned to deal with future attacks not just from supply chain threats, but from ransomware, insider threats, and everything in between.

To wrap up, if there's one lesson to learn from the SolarWinds attack, it's that trust is dangerous when it's blind. A **Zero Trust approach** helps take back control by requiring verification every step of the way. It makes it harder for attackers to blend in, move around, or do damage without being noticed. It's not a silver bullet, but it's a powerful framework that can dramatically improve how digital assets are protected. In a world where cyber threats are constantly evolving, Zero Trust is one of the smartest moves an organization can make.

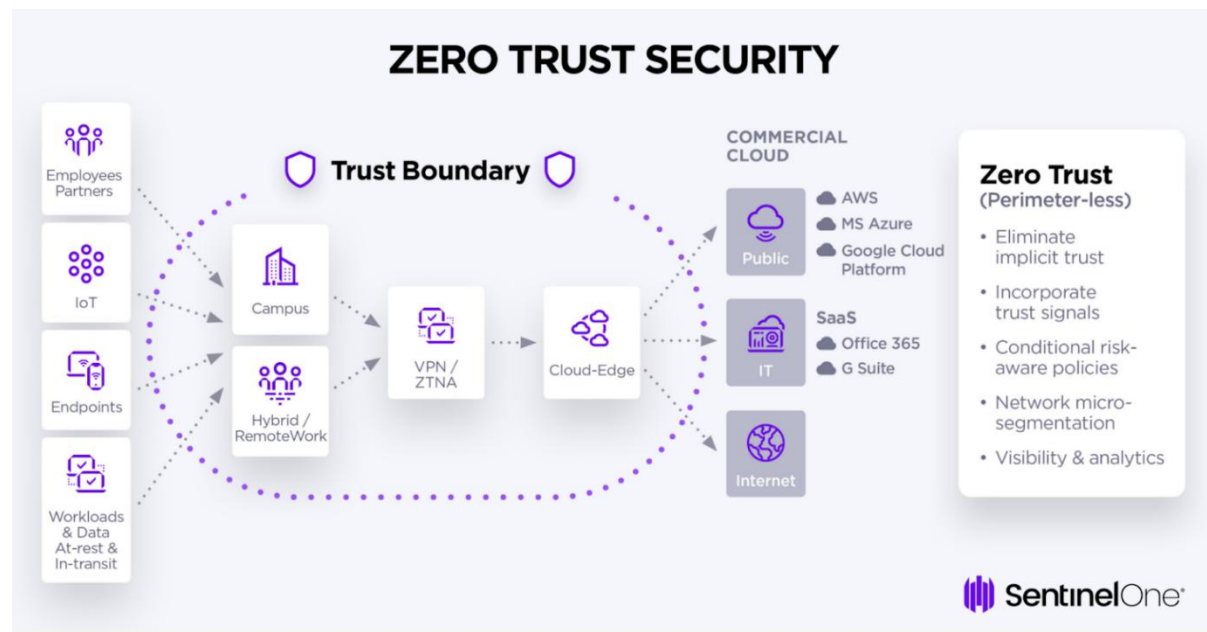


Figure 12: Comprehensive ZTA overview

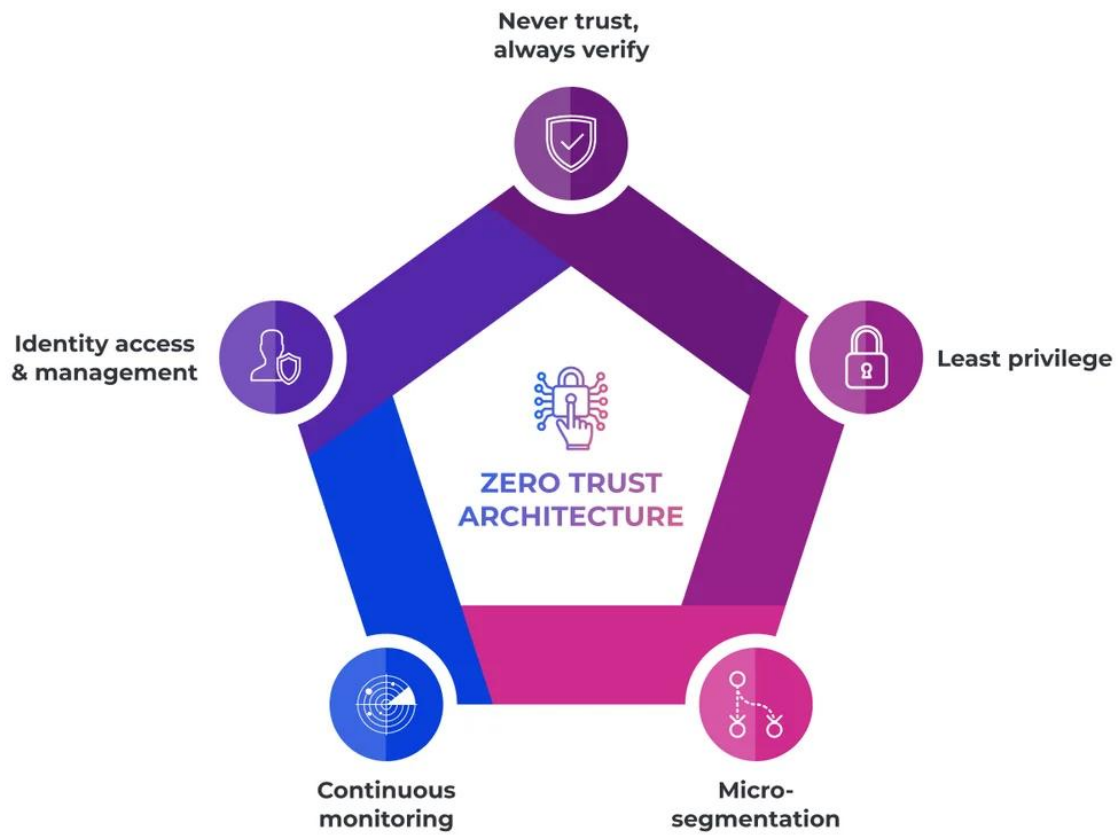


Figure 13: Key components of Zero Trust

4.0 Conclusion

The SolarWinds cyberattack is one of the most significant cybersecurity incidents in recent history, not just because of its technical complexity, but because of how deeply it exposed vulnerabilities across trusted digital ecosystems. This case study shows that even highly secure organizations can be compromised through their supply chains, especially when software updates usually seen as safe are weaponized. The attackers, linked to APT29, used stealthy and well-planned techniques that avoided detection for months, allowing them to extract sensitive data from U.S. government agencies and major tech companies. Their targets ranged from cloud platforms and email systems to Active Directory and software repositories. They also had the potential to reach other critical assets like ICS, SCADA, and communication tools. The tools used, such as SUNBURST malware, forged SAML tokens, and living-off-the-land techniques, made it clear that perimeter security alone is no longer enough. Organizations now face the hard truth: trusting software by default is risky. Moving forward, stronger endpoint protection, real-time monitoring, and zero-trust architecture are no longer optional but necessary. This attack has forced both the public and private sectors to rethink how they approach digital security, and it stands as a wake-up call for global cybersecurity resilience.

Firstly, implementing an Intrusion Detection System (IDS) is one of the most essential ways to improve security in any organization's IT environment. IDS works like a silent observer that constantly watches network and system activity. It doesn't block traffic but rather monitors everything for anything suspicious, such as abnormal login behavior, strange IP connections, or unusual data transfers. In a case like the SolarWinds attack, where the Orion platform was compromised and used to distribute malware to thousands of clients, a properly configured IDS could have identified the unusual behavior much earlier. The attackers were able to stay hidden for months, but with the right detection setup in place, things like lateral movement and odd data flows could have triggered alerts. IDS can also feed into bigger systems like SIEM for further analysis, helping security teams to get the full picture. It's not just about detection, but also about creating logs that help during investigations. While it doesn't actively stop attacks, an IDS plays a vital role in early warning and response, which is often the difference between a minor breach and a major disaster.

Secondly, while IDS detects threats, Security Information and Event Management (SIEM) takes things a step further by analyzing data from multiple sources at once. It collects logs from different systems such as servers, cloud apps, firewalls, and even IDS tools, then analyzes everything together to detect patterns or trends that could point to an attack. In the case of SolarWinds, attackers blended in with regular traffic, which made them hard to detect. But SIEM could have correlated minor events like abnormal logins, unexpected file access, or system configuration changes and pieced them together to reveal the bigger picture. SIEM doesn't just alert security teams but also stores logs for historical review, making it useful even months after an attack. It can also automate responses, such as isolating machines or locking accounts when threats are detected. These features allow organizations to act fast and reduce damage. SIEM's ability to combine internal activity with external threat intelligence means it doesn't just watch, it understands what's happening and can react intelligently.

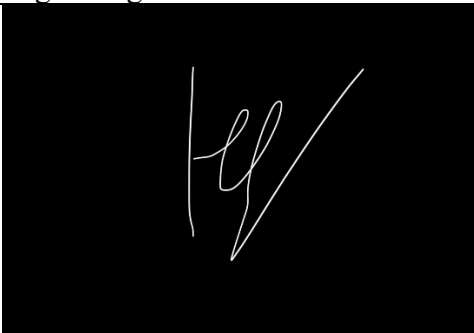
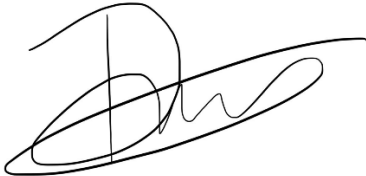
Moreover, strengthening user access through Multi-Factor Authentication (MFA) adds another critical layer of protection. MFA goes beyond basic passwords and requires a second factor like a mobile code, fingerprint, or hardware token before access is granted. This is important because attackers often try to steal credentials and move around a system unnoticed. In the SolarWinds case, even if the malware allowed attackers to get inside the network, MFA could have slowed them down by preventing access to sensitive systems. For example, if an admin's password was stolen, the attacker still couldn't log in without the second verification step. This blocks a lot of lateral movement within the network and keeps high-level access safe. It also reduces the risk of phishing attacks, where users are tricked into giving away passwords. While MFA alone can't prevent all attacks, especially those coming from compromised software like in SolarWinds, it's still a powerful tool in reducing damage once a system is breached. It's easy to implement, cost-effective, and one of the best first steps in any cyber defense plan.

In addition, an Intrusion Prevention System (IPS) offers real-time, automated defense by not just detecting threats, but actively stopping them. Think of it as the aggressive sibling of IDS. While IDS sounds the alarm, IPS blocks the threat before it causes any damage. It works by monitoring network traffic, identifying harmful patterns, and then cutting off suspicious connections. In a breach like SolarWinds, where malware was spread through trusted software updates, an IPS could have detected unauthorized outbound traffic and blocked it instantly. Even

if the malware was already inside, the IPS would prevent it from connecting to command-and-control servers, stopping data theft before it began. IPS can also spot attempts to move laterally within the network, and it blocks malware from spreading further. By identifying both known attack signatures and abnormal behavior, IPS becomes a powerful layer of proactive defense. It makes it way harder for attackers to maintain control of a system once they've broken in, and it buys time for human response teams to step in.

Finally, Zero Trust Architecture (ZTA) is a full shift in how security is managed, and it could have changed everything in a case like SolarWinds. ZTA is based on the idea that no one, not even people or systems already inside the network, should be trusted by default. Instead, every request to access a resource must be verified continuously. This means that even if attackers had managed to get in through the Orion software update, ZTA would have blocked their path at every turn. Access would be based on who the user is, what device they're using, where they're connecting from, and other context. If anything looked suspicious, access would be denied or extra steps like verification would be required. ZTA also uses techniques like micro-segmentation to divide the network, so even if attackers break into one part, they can't reach everything else. Combined with tools like MFA, device compliance checks, and behavior monitoring, Zero Trust makes it incredibly hard for threats to move freely. While it takes time and planning to implement, the benefits in terms of control and protection are worth it. In the world of evolving cyber threats, ZTA helps organizations protect their assets by assuming that no access should ever be trusted blindly.

5.0 Work breakdown Structure

Student Name	Contribution	Digital Signature
HEMANTHRAJAH A/L N KRISHNARAJAH	Introduction Introduction of the Case Proposed Security Techniques – Intrusion Detection Systems (IDS) Conclusion	
ANUSHA DEVY A/P BRAHMATARAN	Attackers Profile Proposed Security Techniques – Intrusion Prevention Systems (IPS)	
DARMIK ISHWAR A/L RAVI	Victims Involved Technology and Tools Used in the Attack Proposed Security Techniques – Zero Trust Architecture (ZTA)	
ADAM JEROME JOSEPH	Other Digital Assets Proposed Security Techniques – Security Information and Event Management (SIEM)	

SAILESS RAJ A/L RAJENDRAN	Targeted System in the Attack Proposed Security Techniques – Multi- Factor Authentication (MFA)	
--------------------------------------	---	---

References

- Arnold & Porter. (2021, June). *Lessons learned from the SolarWinds cyberattack, and the future for regulated entities*. <https://www.arnoldporter.com/en/perspectives/advisories/2021/06/lessons-learned-from-the-solarwinds-cyberattack>
- Aqua Security Software Ltd. (2023, January 18). *SolarWinds attack: Play by play and lessons learned*. <https://www.aquasec.com/cloud-native-academy/supply-chain-security/solarwinds-attack/>
- Cato Networks. (2022). *What is Intrusion Prevention System (IPS)?* <https://www.catonetworks.com/intrusion-prevention-system/>
- CISA. (2020, December 17). *Alert (AA20-352A): Advanced persistent threat compromise of government agencies, critical infrastructure, and private sector organizations*. <https://www.cisa.gov/news-events/alerts/2020/12/17/aa20-352a-advanced-persistent-threat-compromise-government-agencies>
- CISA. (2021). *Advanced persistent threat compromise of government agencies, critical infrastructure, and private sector organizations (Alert AA20-352A)*. <https://www.cisa.gov/news-events/cybersecurity-advisories/aa20-352a>
- CrowdStrike. (2021). *Global threat report*. <https://www.crowdstrike.com/resources/reports/global-threat-report/>
- Das, A. B. (2014). The tangled web of password reuse. *Proceedings of the 21st Annual Network and Distributed System Security Symposium (NDSS)*. https://www.researchgate.net/publication/269197028_The_Tangled_Web_of_Password_Reuse
- FIDO Alliance. (n.d.). *What is FIDO2?* <https://fidoalliance.org/fido2/>
- Florencio, D., & Herley, C. (2007). A large-scale study of web password habits. *Proceedings of the 16th International Conference on World Wide Web*, 667–676. <https://www.scirp.org/reference/referencespapers?referenceid=1737588>
- Fortinet. (2025). *What is an Intrusion Prevention System (IPS)?* <https://www.fortinet.com/resources/cyberglossary/what-is-an-ips>

GeeksforGeeks. (2019, April 9). *Intrusion Prevention System (IPS)*. <https://www.geeksforgeeks.org/intrusion-prevention-system-ips/>

GlobalData. (2023). *SolarWinds Corp company profile*. <https://www.globaldata.com/company-profile/solarwinds-corp/>

IBM. (2023). *What is SIEM?* IBM Security. <https://www.ibm.com/topics/siem>

IBM. (2023, May 10). *Intrusion Prevention System*. <https://www.ibm.com/think/topics/intrusion-prevention-system>

Investopedia. (2024). *How SolarWinds makes money*. <https://www.investopedia.com/how-solarwinds-makes-money-5092559>

Krombholz, K., Hobel, H., Huber, M., & Weippl, E. (2015). Advanced social engineering attacks. *Journal of Information Security and Applications*, 22, 113–122. https://www.researchgate.net/publication/267340031_Advanced_social_engineering_attacks

Michael, S. (2023). *SolarWinds hack explained: Everything you need to know*. WhatIs; TechTarget. <https://www.techtarget.com/whatis/feature/SolarWinds-hack-explained-Everything-you-need-to-know>

MITRE ATT&CK. (n.d.-a). *Technique T1195: Supply chain compromise*. <https://attack.mitre.org/techniques/T1195/>

MITRE ATT&CK. (n.d.-b). *Technique T1550: Use alternate authentication material*. <https://attack.mitre.org/techniques/T1550/>

MITRE ATT&CK. (n.d.-c). *Technique T1557: Adversary-in-the-middle*. <https://attack.mitre.org/techniques/T1557/>

Muhammad, A. R., Sukarno, P., & Wardana, A. A. (2023). Integrated security information and event management (SIEM) with intrusion detection system (IDS) for live analysis based on machine learning. *Procedia Computer Science*, 217, 1406–1415. <https://doi.org/10.1016/j.procs.2022.12.339>

National Institute of Standards and Technology (NIST). (2017). *Digital identity guidelines: Authentication and lifecycle management (SP 800-63B)*. <https://doi.org/10.6028/NIST.SP.800-63b>

Pan, Y., & Li, W. (2023). Improved anomaly detection for network intrusion using hybrid deep learning models. *Journal of Information Security and Applications*, 75, 103652.

Panigrahi, R., Borah, S., Bhoi, A. K., Ijaz, M. F., Pramanik, M., & Jhaveri, R. H. (2024). Overview on intrusion detection systems for computer networking: A comprehensive review. *Computers*, 14(3), 87. <https://doi.org/10.3390/computers14030087>

Palo Alto Networks. (2023). *What is SOAR?* <https://www.paloaltonetworks.com/cyberpedia/what-is-soar>

Palo Alto Networks. (2015). *What is an intrusion prevention system (IPS)?* <https://www.paloaltonetworks.com/cyberpedia/what-is-an-intrusion-prevention-system-ips>

PCI Security Standards Council. (2019). *PCI SSC document library*. https://www.pcisecuritystandards.org/document_library

Safeguard Cyber. (2019, October 9). *Securing Teams and Slack from chat communication risks*. <https://www.safeguardcyber.com/blog/security/securing-teams-slack-chat-communication-risks>

SANS Institute. (2021, February 15). *Shining some light on SolarWinds and ICS*. <https://www.sans.org/blog/shining-some-light-on-solarwinds-and-ics/>

SolarWinds. (2022, August 25). *Double down on your backups*. <https://www.solarwinds.com/blog/double-down-on-your-backups>

SolarWinds. (2023, May 30). *SolarWinds transforms brand to signify ongoing evolution* [Press release]. <https://investors.solarwinds.com/news/news-details/2023/SolarWinds-Transforms-Brand-to-Signify-Ongoing-Evolution-Portfolio-Expansion-and-Customer-Empowerment/default.aspx>

SolarWinds. (2024, April 2). *The best story in software: Celebrating 25 years of SolarWinds*. <https://www.solarwinds.com/blog/the-best-story-in-software-celebrating-25-years-of-solarwinds>

SolarWinds Corporation. (2025, April 16). *Turn/River completes acquisition of SolarWinds* [Press release]. <https://www.solarwinds.com/company/newsroom/press-releases/turnriver-completes-acquisition-of-solarwinds>

Splunk. (2023). *What is Security Information and Event Management (SIEM)?* https://www.splunk.com/en_us/data-insider/what-is-siem.html

TechTarget. (2023, November 3). *SolarWinds hack explained: Everything you need to know.* <https://www.techtarget.com/whatis/feature/SolarWinds-hack-explained-Everything-you-need-to-know>

Temple-Raston, D. (2021, April 16). A “worst nightmare” cyberattack: The untold story of the SolarWinds hack. *NPR*. <https://www.npr.org/2021/04/16/985439655/a-worst-nightmare-cyberattack-the-untold-story-of-the-solarwinds-hack>

Unit 42 (Palo Alto Networks). (2020, December 13). *SolarStorm supply chain attack timeline.* <https://unit42.paloaltonetworks.com/solarstorm-supply-chain-attack-timeline/>

United States Senate Select Committee on Intelligence. (2021). *Report on Russian active measures campaigns and interference in the 2016 U.S. election, Volume 5: Counterintelligence threats and vulnerabilities.* <https://www.intelligence.senate.gov/publications/report-select-committee-intelligence-united-states-senate-russian-active-measures>

VMware. (2025). *What is Intrusion Prevention System?* | VMware Glossary. <https://www.vmware.com/topics/intrusion-prevention-system>